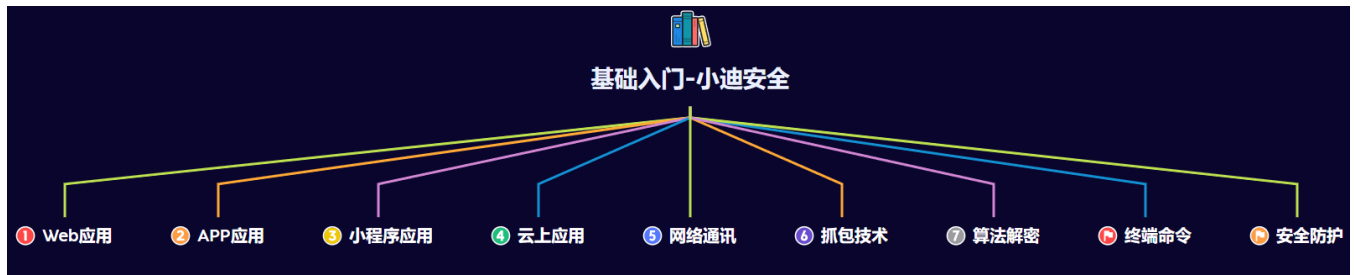


Day10 基础入门-传输加密&数据格式&编码算法&密文存储&代码混淆&逆向保护&安全影响



1.知识点

- 1、基础入门-Web应用-域名上的技术要点
- 2、基础入门-Web应用-源码上的技术要点
- 3、基础入门-Web应用-数据上的技术要点
- 4、基础入门-Web应用-解析上的技术要点

- 1、基础入门-Web应用-搭建架构上的技术要点
- 2、基础入门-Web应用-源码类别上的技术要点

- 1、基础入门-Web应用-防护产品-WAF保护
- 2、基础入门-Web应用-加速服务-CDN节点
- 3、基础入门-Web应用-文件托管-OSS存储
- 4、基础入门-Web应用-通讯服务-反向代理
- 5、基础入门-Web应用-运维安全-负载均衡

- 1、基础入门-Web应用-蜜罐系统
- 2、基础入门-Web应用-堡垒机运维
- 3、基础入门-Web应用-内外API接口
- 4、基础入门-Web应用-第三方拓展架构

- 1、基础入门-APP应用-开发架构安全问题
- 2、基础入门-小程序应用-开发架构安全问题

- 1、抓包技术-Web应用-http/s-Burp&Yakit
- 2、抓包技术-APP应用-http/s-Burp&Yakit

- 3、抓包技术-PC端应用-http/s-Burp&Yakit
- 4、抓包技术-WX小程序-http/s-Burp&Yakit
- 5、抓包技术-软件联动-http/s-Proxifier
- 6、抓包技术-通用方案-http/s-ReqableApi
- 7、抓包技术-其他工具-http/s-Fiddler&Charles

-
- 1、抓包技术-HTTP/S双层代理-扶墙环境
 - 2、抓包技术-HTTP/S上游下游-项目联动
 - 3、抓包技术-全局协议-WireShark&科来

-
- 1、数据不回显原因和解决-带外延迟反弹写文件
 - 2、数据不出网原因和解决-出入站策略正反向连接

-
- 1、反弹Shell-项目&命令&语言等
 - 2、系统渗透命令-网络&文件&操作等

-
- 1、传输格式&数据-类型&编码&算法
 - 2、密码存储&混淆-不可逆&非对称性

2.详细点

- 架构：WEB,APP,小程序,前后端,容器化等
- 服务：OSS存储,CDN加速,云数据库,负载均衡等
- 网络：不回显,反向代理,防火墙出入站,内外网,正反向连接等
- 算法：MD5,Base64,AES,DES,Salt,自定义,代码加密算法等
- 命令：Windows&Linux,文件下载,网络查看,反弹权限,用户等
- 防护：WAF防护,蜜罐系统,CDN加速,权限设置,加壳加密反调试等

3.演示案例

3.1 传输格式&数据-类型&编码&算法

3.1.1 传输格式



```
1 #传输格式
2 JSON XML WebSockets HTML 二进制 自定义
3 WebSockets: 聊天交互较常见（豆包等应用）
4 https://zhuanlan.zhihu.com/p/712032652
```

```
5 https://cloud.tencent.com/developer/article/1917215
6 文件上传：
7 https://www.cnblogs.com/wanglei1900/p/17177303.html
8 影响：安全后渗透测试必须要统一格式发送
```

The screenshot displays the Burp Suite application interface. On the left, the 'Proxying on 192.168.1.4:9000' status is shown. The main panel lists several HTTP requests, with the first one (ID 2158) selected. This request is a POST to 'https://mbd.baidu.com/ztbox?action=zbpglog&appname=pcsearch&sid...' from the 'chrome' application. The right-hand pane shows the raw data of the selected request, including the 'HTTP/1.1 200 OK' status and various headers. A red box highlights a JSON object in the body: '{"error": 0, "logid": "90540897644149995216"}', which is labeled as 'json数据' (JSON data). The bottom status bar indicates '共 7/40 页 (选择 1 页)' (Total 7/40 pages (1 page selected)).

CSDN

博客

下载

学习

社区

C知道

GitCode

InsCode

会议

xml格式

搜索

会员中心

消息

历史

创作中心

发布

m0_73720930: 谈笑风生

xml文件基本格式与解析(一)

山君085: "too young,too simple,sometimes naive" 好评

xml文件基本格式与解析(一)

玻璃心的毛头小子: lz, List nodes = document.selectNodes("/class/part[@id=02]")什...

大家都在看

【闲聊职业规划】001篇-如何做好长期职场规划

springboot毕设毕业生校园招聘系统程序+论文

基于数据可视化++SpringBoot+Vue实现的家政服务管理平台 (2024-2025年设计毕业选题)

node.js毕设排课系统的设计与实现 程序+论文

每日速记10道java面试题08

最新文章

ReentrantLock 和 公平锁

synchronized 浅读解析一

Volatile 浅读解析

你或许以为,你使用JSON格式解析出二进制数据,还可以以本地保存的是XML格式的数据,我自己为解析出二进制数据,然后将其还原成JSON格式传给你,你解析json格式,获得三个数据,再自己构造成xml格式保存起来,说白了,不管是xml还是json,都只是包装数据的不同格式而已,重要的是其中含有的数据,而不是包装的格式。

XML文件创建格式

例:

```
1 <?xml version="1.0" encoding="utf-8" ?>
2 <root>
3   <part id = "01" name="选项一">
4     <name>我是徐茅山</name>
5     <age>今年20岁</age>
6     <sex>男</sex>
7   </part>
8   <part id="02" name="选项二">
9     <name>我是李逍遥</name>
10    <age>今年22岁</age>
11    <sex>男</sex>
12  </part>
13 </root>
```

诸如该数据格式为xml数据格式

开始的

xml文件的解析

这里只是简单的提一下关于xml文件的解析,我使用的是比较流行的dom4j解析,dom4j的文件下载地址("https://dom4i.github.io")

iKun技术记录

关注

21

107

3

分享

专栏目录

文件 工具 代理 证书 帮助

正在共享屏幕 结束共享

正在讲话 小迪安全

启动

self-educated

调试(40)

All Https Websocket HTTP1 HTTP2 JSON XML 文本 HTML JS 图片 媒体 二进制 1xx 2xx 3xx 4xx 5xx

应用程序

2171 GET https://www.baidu.com/content-search.xml chrome

总览 原始 请求头(9) 请求体 Cookies(4)

Text Hex

5 Sec-Fetch-Mode: no-cors

6 Sec-Fetch-Dest: empty

7 User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/129.0.0.0 Safari/537.36

8 Accept-Encoding: gzip, deflate, br, zstd

9 Accept-Language: zh-CN,zh;q=0.9

10 Cookie: BDUSS_BFESS=kdsYzdoOGM8LVp0V0kxOGxNNHRYcWZEand2UzVPaHjxQ1Rnc1p6NWdQRTJYeFpuSVFBQ

11 UFBjCQAAAAAAAAAAAAAAAAAAdB57mY20u5mV; H_WISE_SIDS_BFESS=60278_61027_61098_61141_61175_61

12 207_61213_61212_61208_61238_61188_61280;

13 BAIDUID_BFESS=95A78967A1EA0974B66894B23EBCD577:FG=1;

14 ZFY=kNRMiJdNtrZnJFlsvaBTdGpEzPsdvnpAwYtXXxb68:C

15

16

17

18

19

20

原始 响应头(12) 响应体

Text Hex

7 Date: Sun, 01 Dec 2024 12:17:54 GMT

8 Etag: "ff-51bee881817c8"

9 Expires: Sun, 01 Dec 2024 12:27:54 GMT

10 Last-Modified: Tue, 28 Jul 2015 12:23:03 GMT

11 Pragma: no-cache

12 Server: Apache

13 Vary: Accept-Encoding,User-Agent

14

15

16 <?xml version="1.0" encoding="UTF-8"?>

17 <OpenSearchDescription xmlns="http://a9.com/~spec/opensearch/1.1/">

18 <ShortName>百度搜索</ShortName>

19 <Url type="text/html" template="https://www.baidu.com/s?wd=(searchTerms)" />

20 </OpenSearchDescription>

XML数据格式

共 1/40 项 (选择 1 项)

新版本

2023

2024-12-01

The screenshot shows a web browser with the address bar displaying 'http://www.bilibili.com'. The page content is in Chinese, showing a list of videos. The source code is visible, and a red box highlights the meta tags section. The meta tags include the charset, title, and keywords. The title is '哔哩哔哩 (゜-゜)つロ 干杯~-bilibili'. The keywords are 'bilibili, 哔哩哔哩, 哔哩哔哩动画, 哔哩哔哩弹幕网, 弹幕视频, B站, 弹幕, 字幕, AMV, MAD, MTV, ANIME, 动漫, 动漫音乐, 游戏, 游戏解说, 二次元, 游戏视频, ACG, galgame, 动画, 番组, 番剧, 番音, 初音, self-educated'.

Web 数据传输的方式

自定义数据格式

理想的 **数据结构** 应该是只包含必要的结构，可以简单的包裹起来。例如：

```
1: gdcwxx;gdcwxx@gmail.com;blog.gdcwxx.com
```

解析：

```
function parseCustomType(str) {
  const [, content] = str.split(';');
  const [user, mail, blog] = content.split(';');
  return { user, mail, blog };
}
```

自定义数据格式

目录

- Fetch
- 动态脚本注入
- Multipart XHR
- 发送数据 (Sending Data)
- XMLHttpRequest, Fetch 方式
- 信标方式(Beacons)
- 数据格式 (Data Formats)
- XML
- JSON
- HTML
- 自定义格式
- 结束语

添加站长 进交流群

领取 10元无门槛券，专享 最新干货技术

Proxying on 192.168.1.4:9000

调试(462)

ID	图标	方法	URL	应用程序	总览	原始	请求头(16)	请求体	Cookies(14)
47...	POST	http://mayybnw.3g.qq.com/mayybnw.3g.qq.com:80	192.168						
47...	POST	http://mayybnw.3g.qq.com/mayybnw.3g.qq.com:80	192.168						
45...	POST	http://mayybnw.3g.qq.com/mayybnw.3g.qq.com:80	192.168						
4618	POST	http://mayybnw.3g.qq.com/mayybnw.3g.qq.com:80	192.168						
46...	POST	http://mayybnw.3g.qq.com/mayybnw.3g.qq.com:80	192.168						
45...	GET	https://down11.zol.com.cn/iaotian/ZOL_Android-v10.10.01-full_encrypted_zol-m_14_alig...	chrome						

二进制

原始

Hex

HTTP/1.1 200 OK

Server: openresty/1.9.15.1

Date: Sun, 01 Dec 2024 12:34:03 GMT

Content-Type: application/octet-stream

Content-Length: 78856198

Connection: keep-alive

Last-Modified: Thu, 31 Oct 2024 01:09:12 GMT

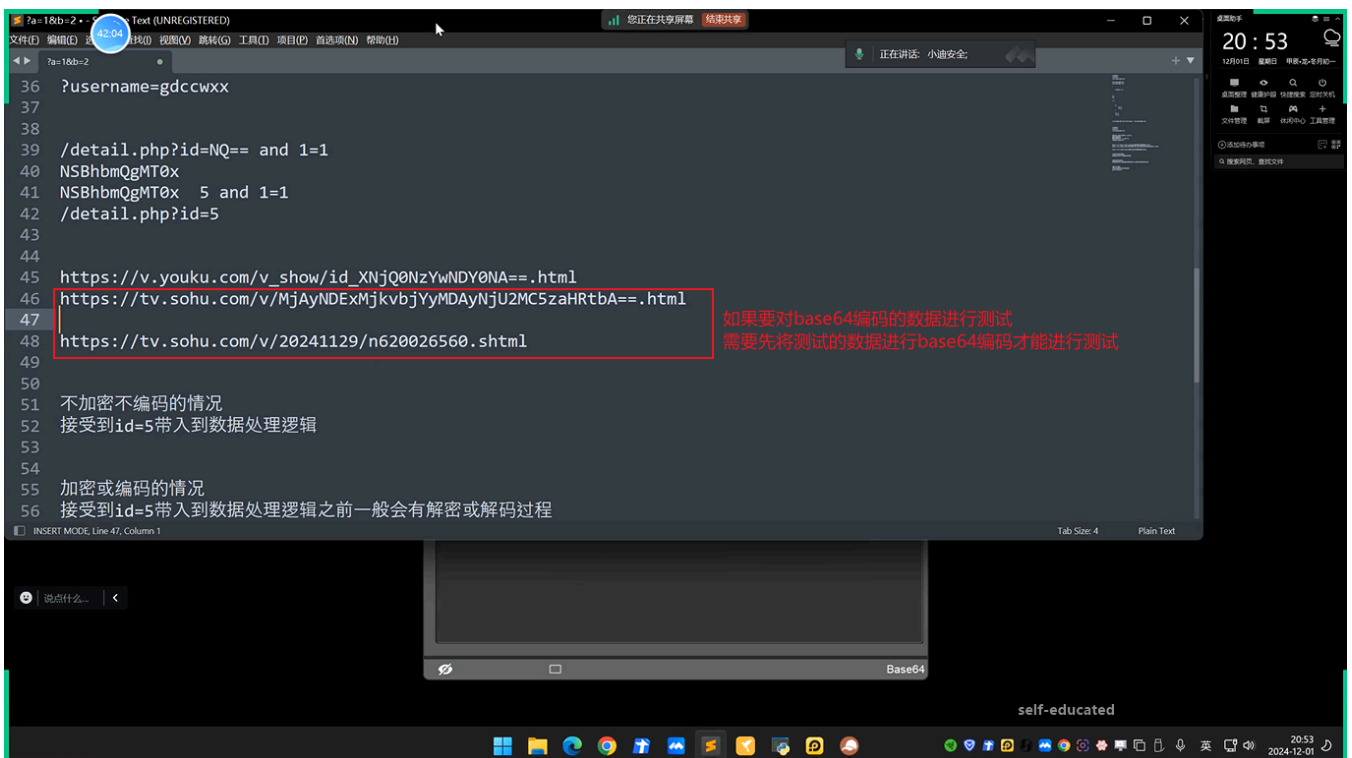
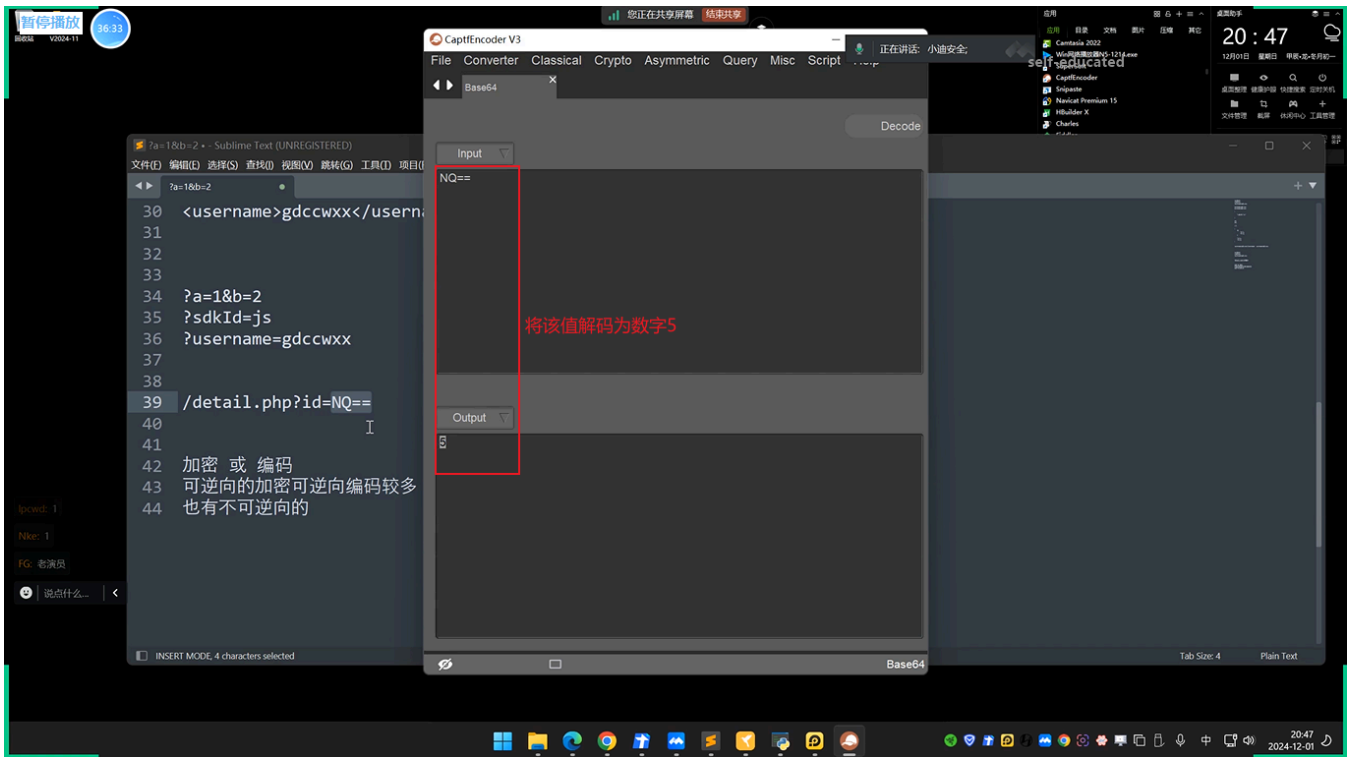
Etag: "722d8b8-4b34006"

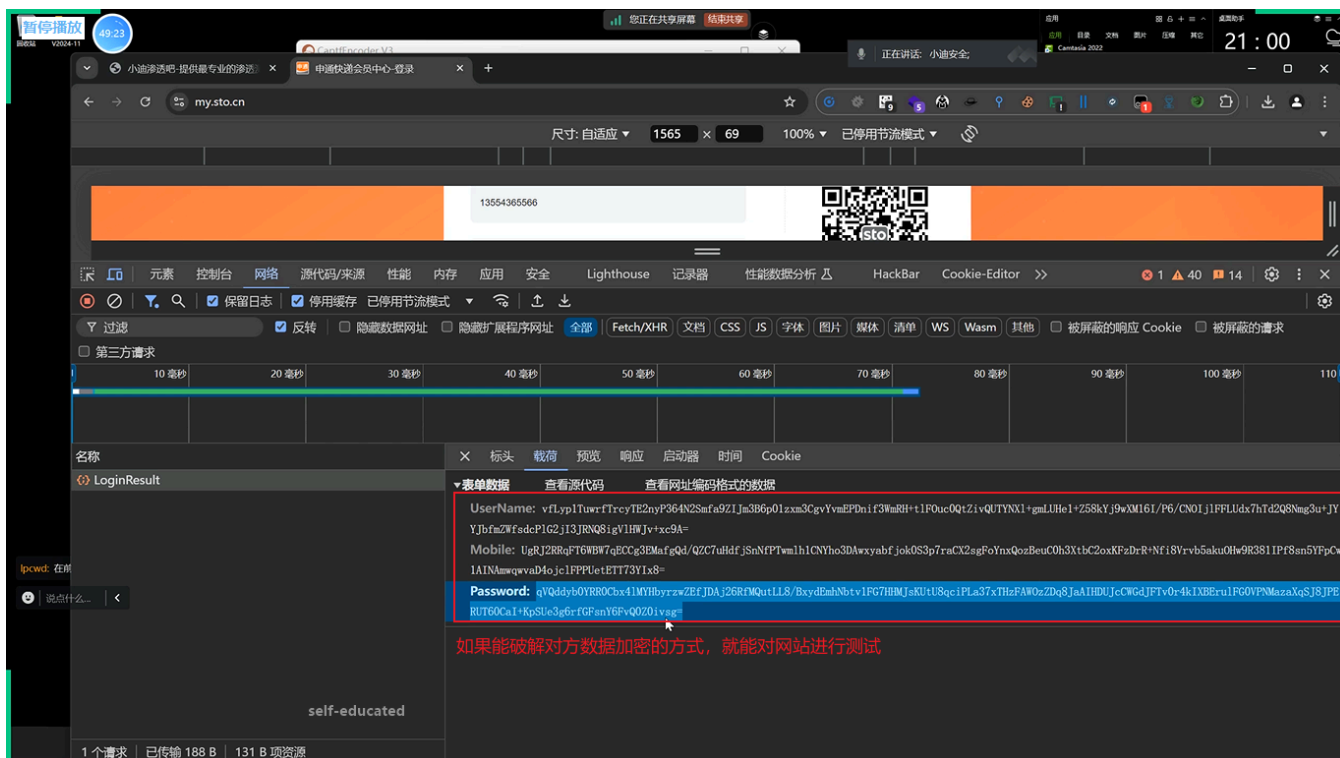
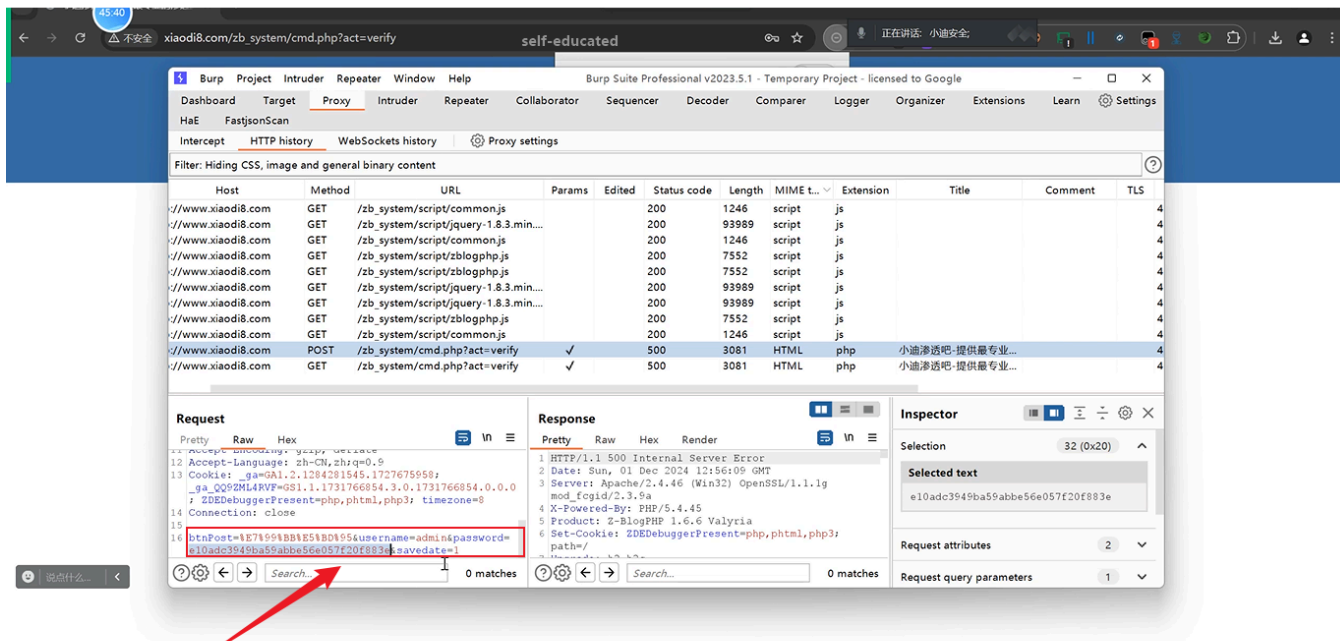
Z-down1: download-sdta18:891

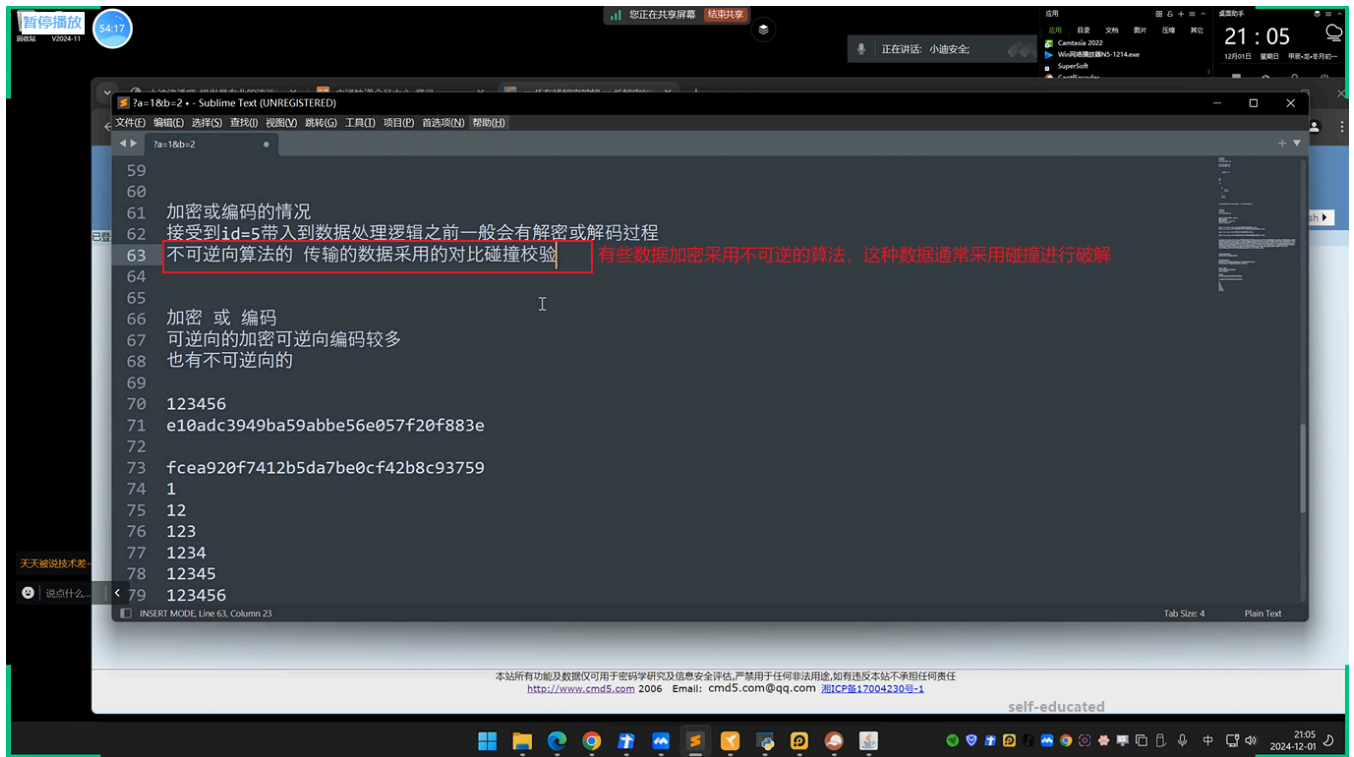
Accept-Ranges: bytes

加载中...

二进制传输格式，多存在于文件下载的时候







3.2 密码存储&混淆-不可逆&非对称性

- 1 由上述内容发现还需那些内容学习:
- 2 1、加密算法的识别与解密
- 3 2、自定义算法的识别解密

3.2.1 密码存储

- 1 #密码存储
- 2 例:
- 3 -ZBlog&Dz
- 4 -win&Linux
- 5 -MSSQL&MYSQL
- 6 影响: 安全后渗透测试必须要做到算法解密

phpMyAdmin interface showing the database structure and a table named `zbp_member`. The table contains one record with the following data:

mem_ID	mem_Guid	mem_Level	mem_Status	mem_Name	mem_Password	mem_Email	mem_HomePage	mem_IP	mem_CreateTime
1	d141bf4b64j56171b2773f902aeafc7	1	0	admin	2088657ac2984b3671c929a811283	null@null.com		27.16.208.81	1733044371

A red arrow points to the `mem_Password` field, indicating the password storage format.

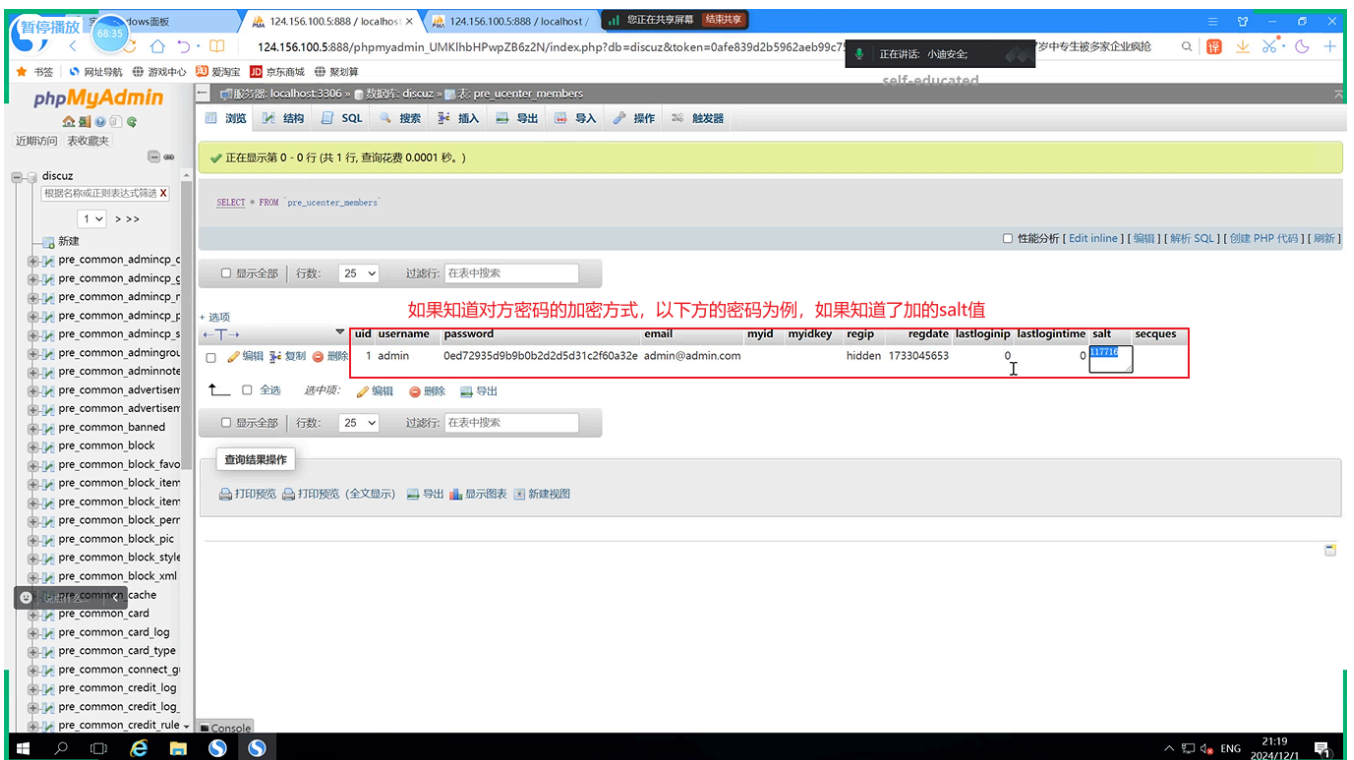
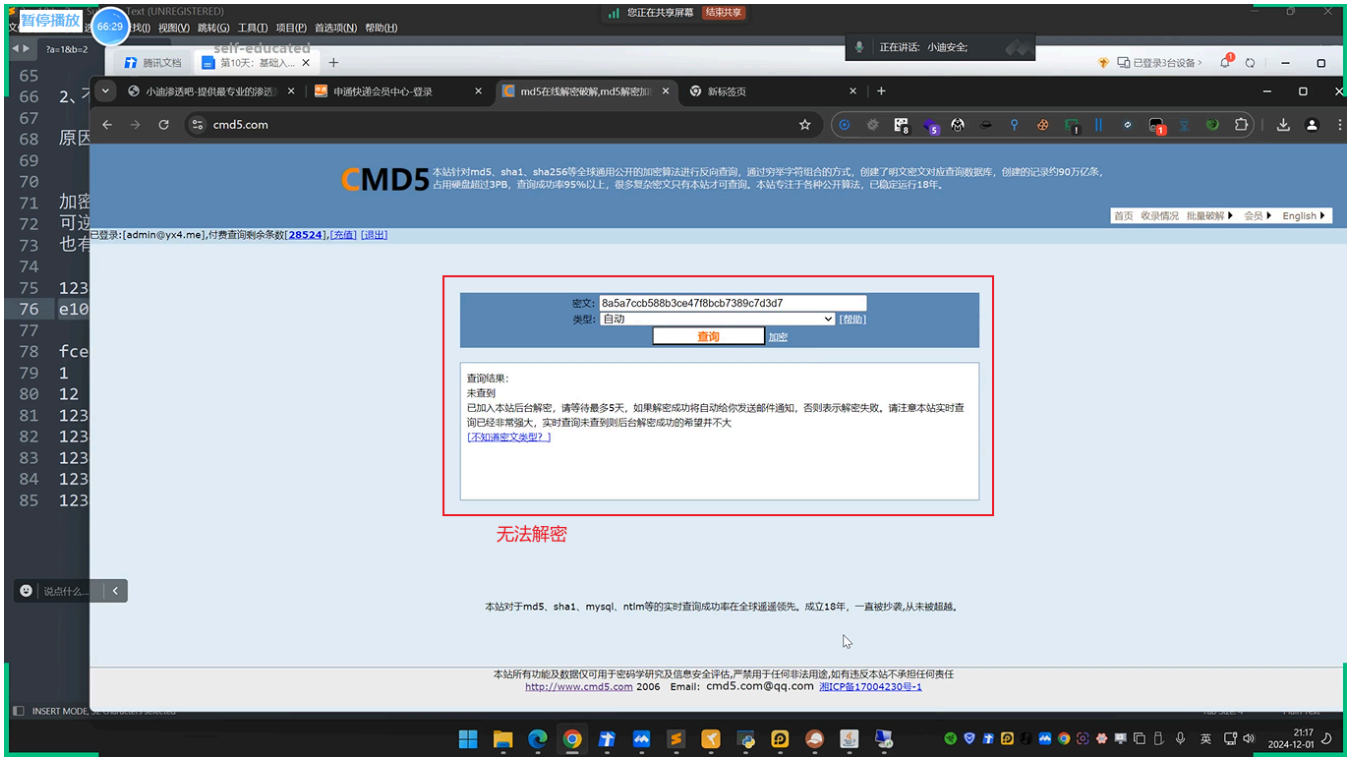
针对z-blog, 密码会以以上方式进行存储

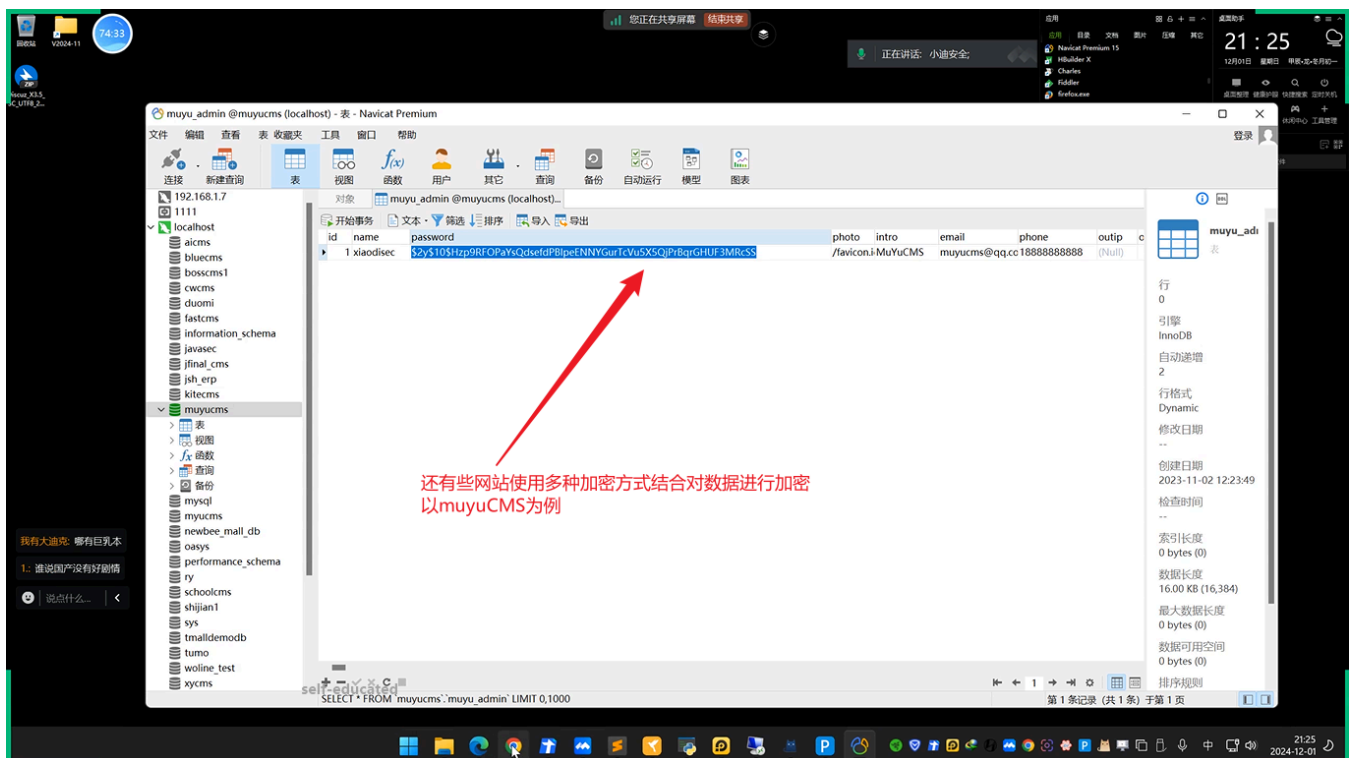
phpMyAdmin interface showing the database structure and a table named `pre_common_member`. The table contains one record with the following data:

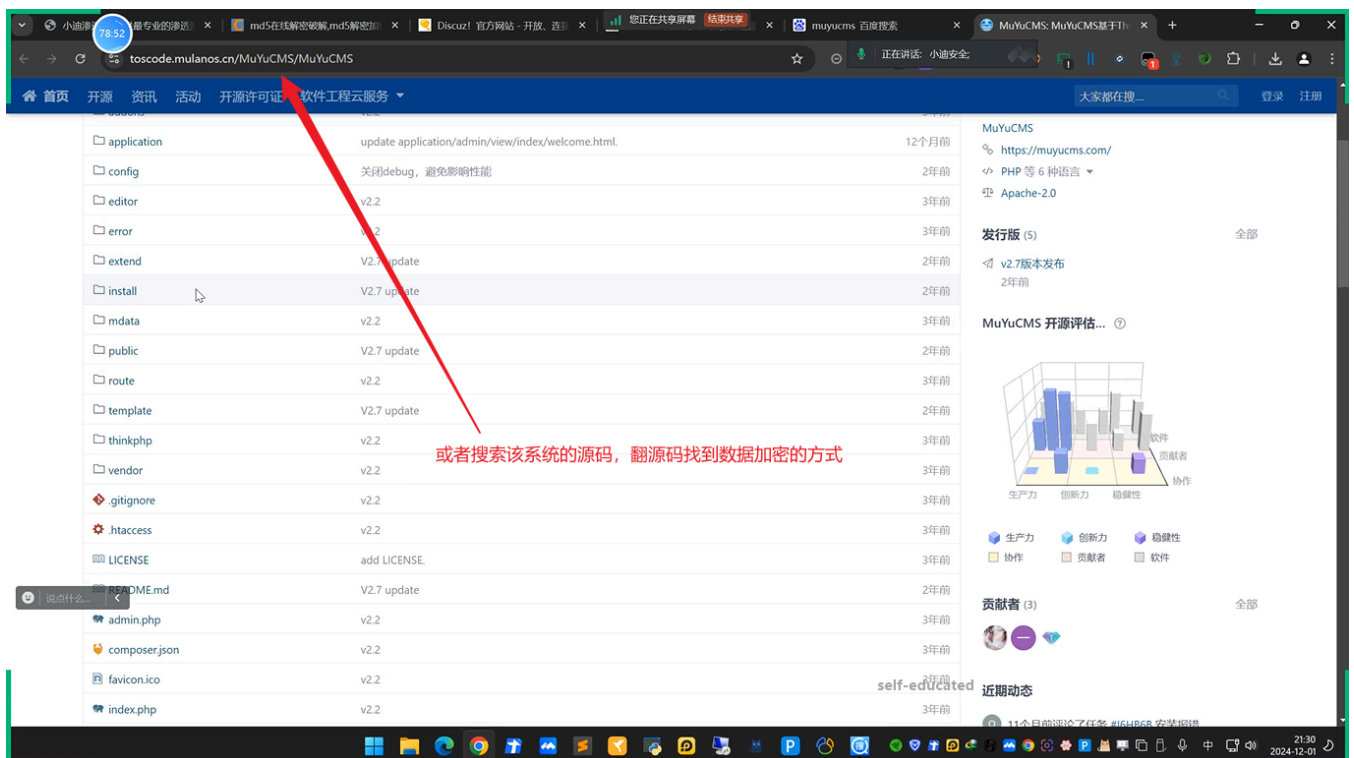
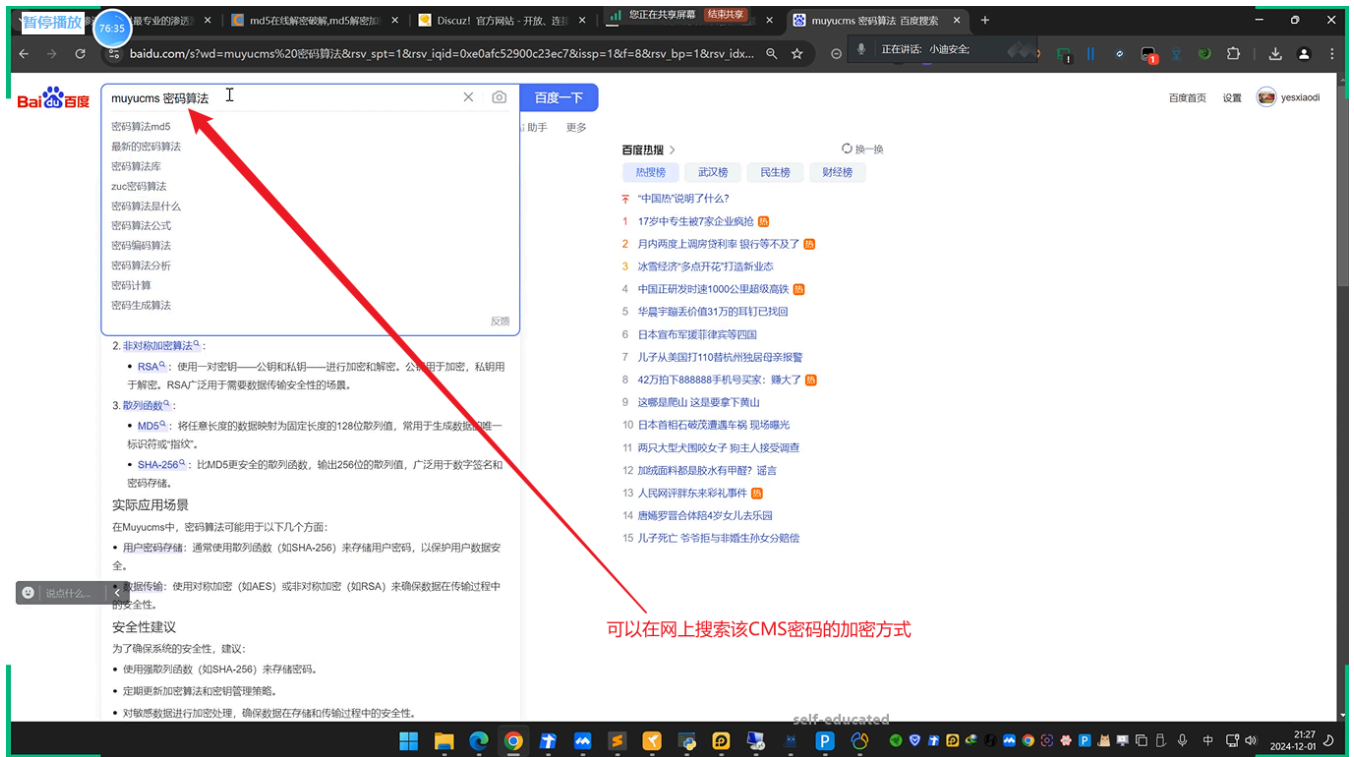
uid	email	username	password	status	emailstatus	avatarstatus	videophotostatus	adminid	groupid	groupexpiry	extgroupids	regdate	credits
1	admin@admin.com	admin	8a5e7cc088b3c47180c87389c7d3d7	0	0	0	0	0	1	1	0	1733045656	2

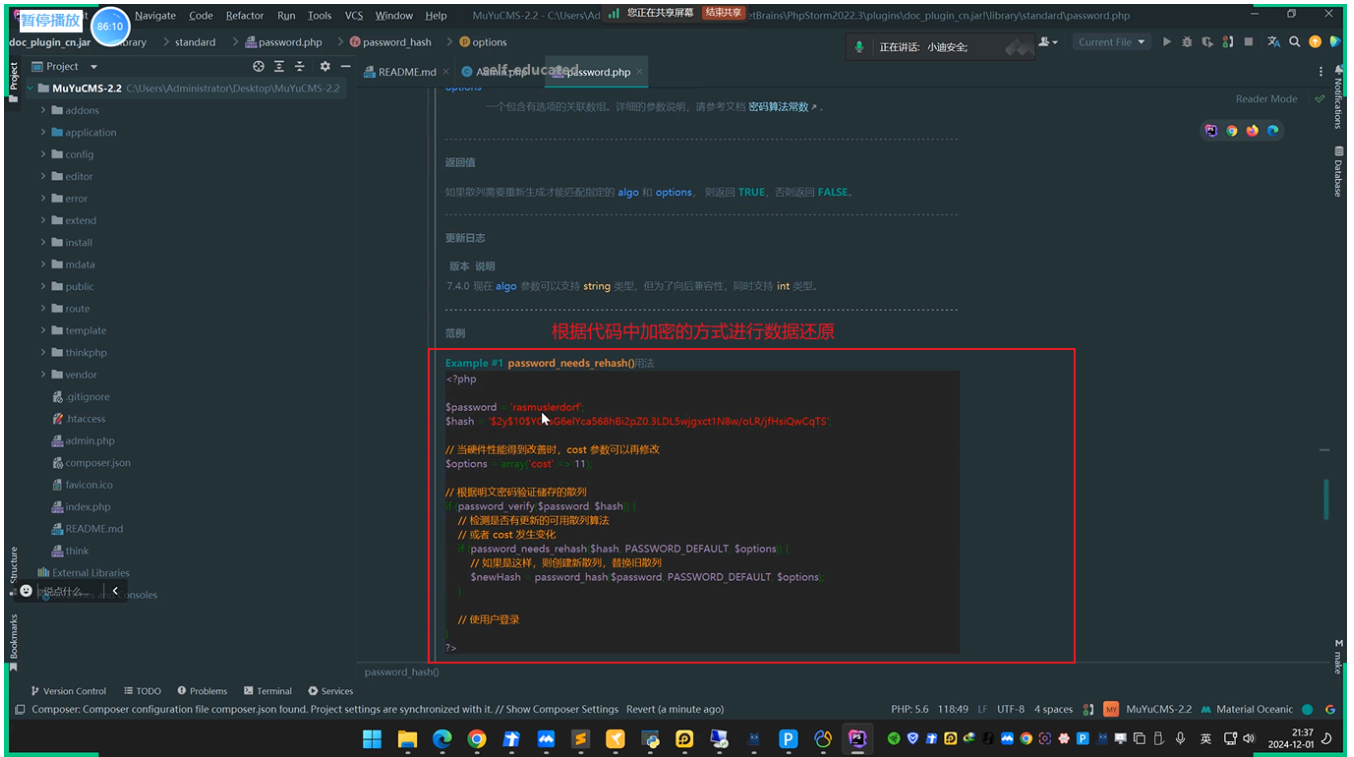
A red arrow points to the `password` field, indicating the password storage format.

尝试对上述密码进行解密









3.2.2 代码混淆

- 1 #代码混淆
- 2 例:
- 3 -PHP&JS混淆加密
- 4 -DLL&JAR代码保护
- 5 影响: 代码审计, 逆向破解

